SANGGABIZ ACADEMY

Product Requirements Document

Sanggabiz LMS v2

Product Requirements Document (PRD)

PRODUK	Sanggabiz LMS v2 — Learning Management System
VERSI DOKUMEN	1.0 · Draft
VERSI PRODUK	v2.0.0 (package.json), cabang `main`
TANGGAL	30 Oktober 2026
DISUSUN UNTUK	Tim internal Sanggabiz Academy (engineering, produk, operasional)
KONTAK	academy@sanggabiz.com
REPOSITORI	github.com/academy-sanggabiz/v2-academy-lms-sanggabiz
STATUS	Dalam pengembangan aktif — belum dirilis ke pengguna produksi (lihat §10 Roadmap)

Dokumen ini merangkum fitur, arsitektur, model keamanan, dan status pengembangan Sanggabiz LMS v2 sebagaimana ada di kode sumber saat ini, agar tim lain (non-engineering maupun engineering) punya pemahaman yang sama sebelum berdiskusi atau membuat keputusan produk.

Daftar Isi

1. Ringkasan Eksekutif
2. Latar Belakang & Tujuan Produk
3. Pengguna Target & Peran Akses
4. Lingkup Fitur Saat Ini
5. Arsitektur & Tumpukan Teknologi
6. Model Data, Keamanan & Hak Akses (RLS)
7. Kualitas: Aksesibilitas, Mobile, Bahasa
8. Lingkungan & Infrastruktur Deployment
9. Metrik / KPI yang Disarankan
10. Roadmap — Belum Dibangun
11. Risiko & Catatan Terbuka
12. Lampiran — Referensi Internal

1. Ringkasan Eksekutif

Sanggabiz LMS v2 adalah Learning Management System yang dibangun ulang (rewrite v2) di atas **Next.js 16**, **React 19**, **TypeScript**, dan **Supabase** (PostgreSQL + Auth + Storage). Produk ini melayani alur belajar lengkap: pembuatan kursus oleh admin, pengiriman materi (video, teks, slide) ke peserta, kuis & penilaian esai, pelacakan progres per pelajaran, hingga penerbitan sertifikat otomatis saat kursus selesai.

Akses diatur dalam tiga peran — **learner** (peserta), **admin**, dan **superadmin** — yang ditegakkan di tingkat basis data lewat Postgres Row-Level Security (RLS), bukan hanya di lapisan aplikasi.

Poin kunci untuk tim yang baru bergabung:

- Produk **sudah fungsional end-to-end** (kursus → belajar → kuis → sertifikat) dan sudah lolos audit aksesibilitas WCAG 2.2 AA (0 pelanggaran axe-core di 26 halaman).
- Sistem pembayaran **belum terhubung ke gateway nyata** — transaksi hari ini hanya mencatat kursus gratis (scaffolding), bukan pemrosesan uang sungguhan.
- Tinjauan keamanan internal (28 Okt 2026) menemukan 17 isu akses data; **sebagian besar sudah diperbaiki**, tapi ada beberapa **isu terbuka berprioritas tinggi** — lihat §11 — yang perlu diketahui sebelum fitur sertifikat/komersial diandalkan penuh.
- Dua jalur deployment disiapkan sekaligus: **Vercel** (Next.js native) dan **Cloudflare Workers** (lewat OpenNext) — keduanya memakai basis kode yang sama.

2. Latar Belakang & Tujuan Produk

Sanggabiz LMS v2 adalah penerus dari versi v1, dibangun mengikuti “Digital Learning Standard” internal milik Sanggabiz (lihat §12) yang menekankan aksesibilitas, kejelasan langkah belajar, dan umpan balik yang mendidik — bukan sekadar nilai benar/salah.

Perubahan utama dari v1 ke v2 yang relevan untuk tim produk:

- **Aksesibel (WCAG 2.2 AA)**: kontras warna diperbaiki, fokus keyboard terlihat jelas, skip-link, target sentuh 24px, dan pelabelan halaman yang benar.
- **Mobile-ready**: pemutar kursus menjadi drawer di layar sempit, tanpa scroll horizontal pada lebar 390px.
- **Satu langkah berikutnya yang jelas**: tombol “Selesai & lanjut” di setiap pelajaran, kartu “Lanjutkan belajar” di dashboard.
- **Umpan balik yang mendidik**: penjelasan per-soal ditampilkan setelah kuis dikumpulkan (disembunyikan sebelumnya oleh RLS, bukan hanya UI).
- **Dibersihkan**: fitur AI Assistant dan tab Notes versi lama dihapus karena terlihat berfungsi tapi sebenarnya tidak — digantikan fitur Catatan Saya yang baru dan benar-benar tersimpan (lihat §4).

3. Pengguna Target & Peran Akses

Peran disimpan di tabel `profiles`, otomatis terisi saat pendaftaran, dan dicerminkan ke token sesi (JWT) lewat custom access-token hook Supabase. Peran **tidak pernah bisa diubah oleh pengguna sendiri lewat aplikasi** — hanya lewat akses database langsung oleh tim internal, by design.

Peran	Siapa	Yang bisa dilakukan
Learner	Peserta yang mendaftar sendiri	Menjelajah & mendaftar kursus publik, belajar, mengerjakan kuis/esai, melihat progres, menulis catatan pribadi, mendapatkan sertifikat otomatis saat lulus.

Peran	Siapa	Yang bisa dilakukan
Admin	Pengelola kursus (instruktur/tim konten)	Membuat & mengelola **kursus miliknya sendiri** (bukan semua kursus) — materi, kuis, modul, harga, status publish/privat; mengelola peserta kursusnya; menilai esai; melihat pembelian & statistik untuk kursusnya.
Superadmin	Pengelola platform	Semua hak admin, **untuk semua kursus tanpa batas kepemilikan** (superset penuh), ditambah mengedit halaman landing publik dan mengatur template sertifikat platform.

Catatan desain penting: admin bersifat *multi-tenant* — setiap admin hanya melihat dan mengelola kursus yang ia buat sendiri (`courses.created_by`), ditegakkan oleh RLS lewat fungsi `owns_course()`, bukan filter di kode aplikasi. Superadmin adalah satu-satunya peran yang melihat lintas-kursus.

4. Lingkup Fitur Saat Ini

Berikut fitur yang **sudah berjalan** di kode saat ini, dikelompokkan per area produk.

4.1 Manajemen Kursus (Admin)

- Editor pelajaran rich-text (Tiptap) dengan gambar, heading, warna, highlight.
- Pelajaran video (YouTube) dan Google Slides.
- Resource unduhan per pelajaran.
- Modul (section) dengan urutan pelajaran drag-and-drop.
- Prasyarat antar-kursus.
- Alur draft → publish dengan live preview sebelum dipublikasikan.
- Upload thumbnail kursus via Supabase Storage.

4.2 Pengalaman Belajar (Learner)

- Pemutar pelajaran full-screen, mode drawer otomatis di layar sempit.
- Centang selesai per pelajaran dengan progress bar real-time.
- Kuis interaktif (pilihan ganda satu/banyak jawaban, jawaban singkat).
- Tugas esai / studi kasus dengan draft yang tersimpan otomatis di server (tidak hilang saat refresh/ganti perangkat).
- **Catatan Saya** per pelajaran — privat untuk peserta, autosave, tidak bisa dibaca admin/superadmin (sengaja, karena ini catatan belajar pribadi bukan bukti penilaian).
- Sertifikat diterbitkan otomatis saat semua pelajaran selesai dan semua kuis lulus.

4.3 Mesin Asesmen & Penilaian

- Tipe soal: pilihan ganda (satu/banyak jawaban), jawaban singkat, esai.
- Pengaturan per kuis: skor kelulusan, jumlah percobaan, batas waktu, acak urutan soal.
- Penilaian otomatis di server untuk soal objektif.
- Alur penilaian manual untuk esai (menu Admin → Grading), dengan sanitasi jawaban sebelum ditampilkan ke admin.
- Penjelasan per-soal baru terbuka untuk peserta *setelah* kuis dikumpulkan.

4.4 Sertifikat

- Terbit otomatis saat syarat kelulusan terpenuhi.

- Template, tanda tangan, nama/gelar penandatangan, dan jenis sertifikat bisa diatur admin/superadmin.
- Ekspor PDF disimpan di Supabase Storage.
- **Catatan risiko:** penerbitan saat ini berjalan di sesi peserta sendiri — lihat isu keamanan C-05 di §11 sebelum sertifikat dipakai sebagai bukti resmi tanpa verifikasi admin.

4.5 Perangkat Admin & Superadmin

- Manajemen kursus penuh (buat, edit, publish, hapus) — terbatas pada kursus milik sendiri untuk admin biasa.
- Manajemen peserta — mendaftarkan / membatalkan pendaftaran peserta ke kursus yang dimiliki.
- Manajemen pembelian (purchase) — hari ini hanya mencatat kursus gratis/berbayar sebagai data, belum ada pemrosesan uang nyata (lihat §10 Roadmap).
- Manajemen template sertifikat.
- Halaman landing publik yang bisa diedit (khusus superadmin).
- Kontrol akses berbasis peran ditegakkan lewat Postgres RLS, bukan hanya pengecekan di UI.

4.6 Kursus Privat & Undangan

- Kursus bisa ditandai **Privat** — tidak muncul di katalog publik, hanya bisa diakses peserta yang diundang.
- Tab Learners di editor kursus untuk mencari & mengundang peserta yang belum terdaftar.
- *Keterbatasan yang disengaja:* kursus berstatus draft + privat sekalipun tidak terlihat oleh peserta yang sudah diundang — pesan ini ditampilkan di UI agar tidak dikira bug.

4.7 Notifikasi

- Sistem notifikasi dasar di dalam aplikasi untuk peserta (lihat §10 — notifikasi email belum ada).

5. Arsitektur & Tumpukan Teknologi

Lapisan	Teknologi
Framework	Next.js 16 (App Router, Turbopack) — perhatian: Next.js 16 punya perubahan besar ("proxy.ts" menggantikan "middleware.ts", API async-only); lihat AGENTS.md/CLAUDE.md di repo sebelum coding.
Bahasa & UI	TypeScript · React 19 · Tailwind CSS v4 · shadcn/ui + Radix · Lucide icons · Sonner (toast)
Tema	next-themes (mode terang/gelap)
Basis data & Auth	Supabase — PostgreSQL + Auth (@supabase/ssr) + Storage, diakses lewat kunci anon/authenticated; hampir semua akses data ditegakkan oleh RLS, bukan oleh service-role key
Form & validasi	React Hook Form + Zod
Rich text	Tiptap
Drag & drop	dnd-kit
PDF	@react-pdf/renderer (sertifikat)
Deployment	Dua target: Vercel (native Next.js) dan Cloudflare Workers lewat OpenNext — kode sama, dipilih lewat variabel DEPLOY_TARGET

6. Model Data, Keamanan & Hak Akses (RLS)

Prinsip inti: **otorisasi ditegakkan di database** (Postgres Row-Level Security), bukan hanya di kode aplikasi. Ini berarti sekalipun ada celah di halaman/komponen React, API Supabase yang diakses langsung tetap menolak baris yang tidak berhak dibaca/ditulis oleh pengguna tersebut.

Entitas data utama:

- `profiles` → peran pengguna, 1:1 dengan akun auth.
- `courses` → `course_sections` → `lessons` → `resources` (struktur kurikulum).
- `quizzes` → `questions` → `question_options`, `quiz_attempts`, `quiz_responses` (asesmen).
- `enrollments` (pendaftaran peserta), `lesson_progress`, `certificates`, `transactions` (pembelian), `lesson_notes` (catatan pribadi).

6.1 Tinjauan Keamanan Internal (28 Oktober 2026)

Tim melakukan audit RLS end-to-end pada 28 Oktober 2026, menemukan 17 isu dengan rincian: **1 Critical, 4 High, 4 Medium, 4 Low, 4 Info**. Sembilan di antaranya sudah diperbaiki. Ringkasan temuan berdampak paling besar:

ID	Tingkat	Ringkasan	Status
C-01	Critical	Peserta bisa mengubah perannya sendiri menjadi superadmin lewat API langsung.	**Fixed**
C-02	High	Isi pelajaran & jawaban kuis kursus publik bisa dibaca tanpa login lewat API.	**Fixed**
C-03	High	Peserta bisa memalsukan status lulus kuis / membuka kunci jawaban sebelum mengerjakan.	**Fixed**
C-04	High	Peserta bisa memindahkan pendaftarannya ke kursus privat lain tanpa izin.	**Fixed**
C-05	High	Peserta bisa menerbitkan sertifikatnya sendiri secara curang lewat API langsung.	**Open**
C-06	Medium	Nilai esai bisa dinaikkan sendiri oleh peserta lewat manipulasi baris jawaban.	**Fixed**
C-08	Medium	Semua berkas di penyimpanan (termasuk PDF sertifikat peserta lain) bisa didaftar publik.	**Fixed**
C-09	Medium	Konten HTML buatan admin dirender tanpa sanitasi — celah XSS potensial.	**Open**
C-12	Low	Gambar pelajaran & PDF sertifikat bisa diunduh siapa saja yang tahu URL-nya (URL acak, sulit ditebak).	**Open (diterima)**

Daftar lengkap 17 temuan ada di `docs/SECURITY-REVIEW.md` pada repositori. Dua isu **Open** berdampak tinggi (C-05, C-09) dibahas lagi di §11 sebagai risiko yang perlu keputusan produk, bukan sekadar pekerjaan teknis.

7. Kualitas: Aksesibilitas, Mobile, Bahasa

- **Aksesibilitas:** audit otomatis axe-core (WCAG 2.2 A/AA) melaporkan **0 pelanggaran di 26 halaman** (`npm run audit:a11y`). Mencakup kontras warna ≥4.5:1, fokus keyboard terlihat, skip-link, target sentuh 24px, reorder pelajaran lewat keyboard, dan alt text gambar.

- **Mobile:** pemutar kursus otomatis menjadi drawer di layar sempit; tidak ada scroll horizontal pada lebar 390px.
- **Bahasa:** antarmuka saat ini sudah berjalan dalam **Bahasa Indonesia** (termasuk saat diuji langsung di aplikasi berjalan) — ini lebih maju dari catatan roadmap README yang masih menandainya "belum selesai"; perlu konfirmasi ke tim engineering apakah proses lokalisasi sudah dianggap tuntas.
- **Belum ada automated test suite** (unit test) — definisi selesai untuk perubahan UI saat ini adalah: typecheck, lint, build, audit a11y, dan pengecekan manual manual di lebar 390px dengan keyboard saja.

8. Lingkungan & Infrastruktur Deployment

Satu basis kode, dua target deployment yang bisa dipilih lewat variabel lingkungan `DEPLOY_TARGET`:

- **Vercel** — menjalankan Next.js secara native. Proyek sudah terhubung (linked) ke tim Vercel organisasi.
- **Cloudflare Workers** (lewat OpenNext) — untuk skenario yang membutuhkan edge runtime Cloudflare.
- **Supabase** — proyek database/auth/storage terpisah per lingkungan; proyek saat ini baru dipindah ke instans Supabase v2 yang baru (per catatan commit terbaru).
- Variabel wajib: `NEXT_PUBLIC_SUPABASE_URL`, `NEXT_PUBLIC_SUPABASE_PUBLISHABLE_KEY`; opsional server-only: `SUPABASE_SERVICE_ROLE_KEY` (hanya dipakai fitur hapus akun) dan kunci hCaptcha.

9. Metrik / KPI yang Disarankan

Mengacu pada Standar Digital Learning internal (§12 dokumen tersebut), produk ini belum punya KPI resmi yang terdefinisi — ini adalah **rekomendasi**, bukan metrik yang sudah berjalan. Standar menyarankan maksimal tiga KPI utama, masing-masing dengan definisi, baseline, dan target tertulis sebelum perubahan dilakukan:

KPI	Definisi	Jebakan yang perlu dihindari
Completion rate	Jumlah selesai ÷ jumlah mulai	Hanya menghitung peserta yang bertahan sampai akhir — bisa menyembunyikan drop-out dini
Engagement (return rate)	Peserta kembali dalam 7 hari	Jangan disamakan dengan jumlah klik semata
Drop-out rate	Keluar dalam rentang waktu tertentu ÷ jumlah mulai	Rentang waktu harus didefinisikan jelas, bukan dibiarkan terbuka

Sebagai pembanding eksternal (bukan target): median completion rate MOOC di berbagai studi berkisar 12,6% (rentang 0,7–52,1% dari 221 kursus yang diteliti), dengan dua minggu pertama sebagai periode paling kritis untuk drop-out.

10. Roadmap — Belum Dibangun

Berikut yang secara eksplisit **belum dibangun** per dokumentasi internal (erd.md / README):

- **Integrasi payment gateway** — saat ini komersial hanya scaffolding kursus gratis; alur pembayaran nyata belum ada.
- **Kategori kursus** — belum ada tabel/kolom/filter kategori.
- **Brand settings** — nama situs, logo, warna utama belum punya layar pengaturan khusus (baru sebagian tertutup oleh editor landing page).
- **Notifikasi email** — pendaftaran / penyelesaian kursus / sertifikat belum mengirim email.

- Tipe soal kuis tambahan (matching, isian kosong) — sudah dicadangkan di enum database, belum diimplementasikan.
- **Learning analytics** — completion rate, return rate 7 hari, drop-out minggu pertama (lihat §9) belum punya dashboard.

11. Risiko & Catatan Terbuka

Hal-hal berikut perlu keputusan produk/bisnis, bukan sekadar backlog teknis:

- **Keaslian sertifikat (C-05, High, Open):** penerbitan sertifikat saat ini berjalan di sesi peserta sendiri, sehingga secara teknis peserta bisa membuat sertifikat palsu lewat panggilan API langsung (bukan lewat tampilan aplikasi normal). **Jangan jadikan sertifikat sebagai bukti resmi tanpa verifikasi admin** sampai perbaikan ini selesai (memindahkan penerbitan ke fungsi database yang tepercaya).
- **Konten tanpa sanitasi (C-09, Medium, Open):** HTML yang ditulis admin (materi, soal) dirender tanpa dibersihkan dari skrip berbahaya — celah XSS potensial yang bisa dieksploitasi jika akun admin disusupi.
- **Belum ada pemrosesan pembayaran nyata** — jangan mengomunikasikan ke pelanggan bahwa kursus berbayar sudah bisa ditransaksikan sampai gateway pembayaran terhubung.
- **UI sudah berbahasa Indonesia** namun status ini belum dikonfirmasi tim engineering sebagai “selesai” secara resmi — perlu sinkronisasi dokumentasi roadmap.
- **Belum ada automated test suite** — risiko regresi lebih tinggi saat beberapa orang mengubah kode bersamaan.

12. Lampiran — Referensi Internal

Dokumen ini dirangkum dari sumber-sumber berikut di repositori; rujuk langsung untuk detail teknis:

Dokumen	Isi
README.md	Ringkasan fitur, tech stack, cara instalasi, struktur proyek, roadmap
CLAUDE.md / AGENTS.md	Catatan arsitektur mendalam & konvensi Next.js 16 untuk engineering
docs/SECURITY-REVIEW.md	17 temuan tinjauan keamanan RLS secara lengkap, metode pengujian
docs/STANDAR-DIGITAL-LEARNING.md	Standar UX, learning science, WCAG 2.2, dan KPI internal Sanggabiz
docs/V2-UPGRADE.md	Rincian perubahan v1 → v2 dan cara verifikasinya
docs/DEPLOY-VERCEL.md	Panduan deploy ke Vercel: Supabase, env var, redirect auth
supabase/migrations/	Riwayat perubahan skema database & kebijakan akses (RLS), terurut kronologis

Dokumen ini dibuat otomatis dari pembacaan kode sumber & dokumentasi internal pada 30 Oktober 2026. Untuk perubahan produk setelah tanggal ini, mohon perbarui dokumen ini atau tandai sebagai kedaluwarsa.